

Active Directory Enumeration & Attacks

Catégorie : ⚔ Offensif
Difficulté : Medium, Tier II
Durée Estimée : 7 jours

Introduction à l'Enumeration et aux attaques AD:

Active Directory est un service d'annuaire dominant de Microsoft (43% d entreprises mondiales en 2026) utilisé dans les réseaux d'entreprises pour gérer les utilisateurs, les ordinateurs et les ressources. Sa complexité crée une grande surface d'attaque.
L'objectif principal du pentest AD est de trouver des mauvaises configurati et des vulnérabilités pour élever les privilèges, se déplacer latéralement et fi nalement atteindre la compromission du domaine (par exemple l'accès Admi nistrateur de Domain)

- Une compétence essentielle consiste à utiliser des outils intégrés au sy stem d'exploitation, (Living Off The Land) pour l'enumération et les atta ques, ce qui est necessaires pour être discret, et/ou lorsque les outils perso- nalisés sont bloqués ou indisponibles. On doit être adaptable et à l'aise pour attaquer depuis des environnement Windows et Linux, avec un ensemble d'o tils très limité, sur un poste de travail géré.

L'objectif dans ce module est de comprendre l'attaque pas les outils.

Principes Généraux Reconnaissance Externe:

C'est la phase initial du test d'intrusion l'ayant déja documenté avant je reprend quelques bases. L'objectif est de collecter un maximum d'inform ation publique sur la cible pour comprendre son infrastructure identifier des failles de sécurité potentielles (fuites d'identifiants) et valider le périmètre d'au dit.

- Blocs d'adresses IP (ASN) enregistrement DNS, sous domaines et services publics (VPN, Serveurs Mail). Pour l'analyse IP/ASN: https://bgp.he.net pour l'analyse DNS et Domaines: https://www.domaintools.com ou https://viewdns.info Il est important de checker et s'interesser aux conventions de nommages pour les emails et noms d'utilisateurs (ex: prenom.nom@entreprise.com).

- Les fuites de données et données de bricks: Information sensibles dans les document publiques (Google Dork) et les réseaux sociaux, les métadonnées et du code sur des plateformes comme github. Et aussi et surtout les emails avec credentials issues de fuites de données. (necessiteront souvent des accès pa yant)
  Pour les stockages cloud ouverts: https://greyhatwarfare.com
  Recherche de données de bricks: https://haveibeenpwned.com
  Donnée de bricks et mdp si tu paie: https://www.dehashed.com

N'oublions pas de croiser et verifier nos informations de les stocker aussi on doit faire un vrai travail d'enquete cartographier de l'exterieur le plus po ssible l'entreprise et reunir autant de donnée que possible "ayant la plus gran de valeur possible".

Après cet "Reconnaissance Hors Module", Enumeration Initiale du Domain:

On commence les choses serieuses (pour ces modules car une bonne reco ext erne est INDISPENSABLE...